

Hardcoded Credentials (OWASP Mobile M1)

È stata identificata una stringa di autenticazione statica utilizzata nelle chiamate API dell'app Booking.com. Questa stringa, una volta decodificata (Base64), rivela credenziali fisse incorporate nel codice sorgente (APK). La loro natura statica permette a chiunque di poter interagire con l'API interna dell'app.

Proof of Concept

Grazie ad un'analisi del traffico di Booking.com tramite Charles Proxy, negli headers viene notata la presenza di un'autenticazione di tipo *Basic*:

The screenshot shows the Charles Proxy interface. On the left, a list of requests is visible, with the selected request being a POST to `https://mobile-apps.booking.com/json/mobile.getExperimentsv2?notification_auth_status=1&user_os=13&user_version=60.2.1.11-android&device_id=ae521a5a-eb4d-4bfa-a16d-50374d9388c5&network_type=wifi&languagecode=en-us&display=normal_XXXdpi&affiliate_id=337862`. The main pane displays the request details, including the headers section which shows the following authentication information:

Header	Value
<code>authorization</code>	<code>Basic dGhkczFpbmRzYnY6ZGdVbnhcXCeGdN</code>
<code>x-bookings-api-version</code>	<code>1</code>
<code>content-type</code>	<code>application/json; charset=utf-8</code>

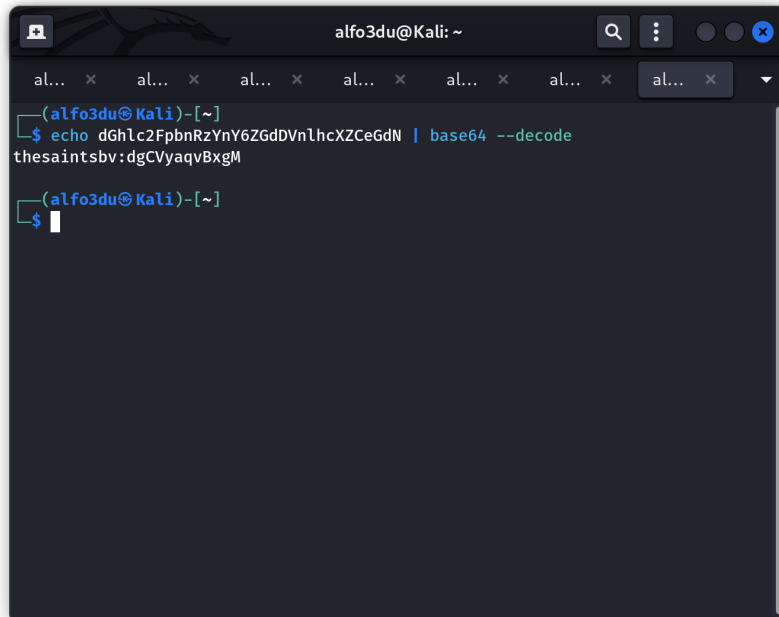
The body of the request is a JSON object containing experimental data and user information, including a `device_id` and a `user_id`.

La sezione *Authentication* segnala ancora più evidentemente l'utilizzo di credenziali in chiaro:

This close-up view of the `Basic Authentication` section in Charles Proxy shows the decoded credentials:

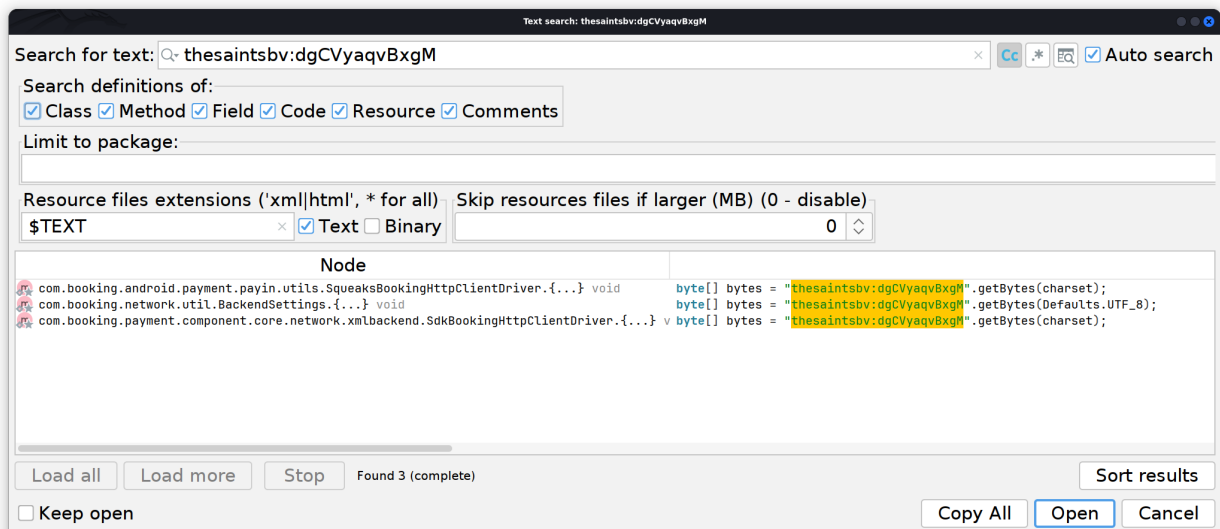
Field	Value
User ID	<code>thesaintsbv</code>
Password	<code>dgCVyaqvBxgM</code>

L'autenticazione di tipo *Basic* prevede l'utilizzo di Base64. Una semplice decodifica della stringa catturata da Charles rivela le credenziali, che corrispondono a quelle presenti nella sezione di *Authentication*:

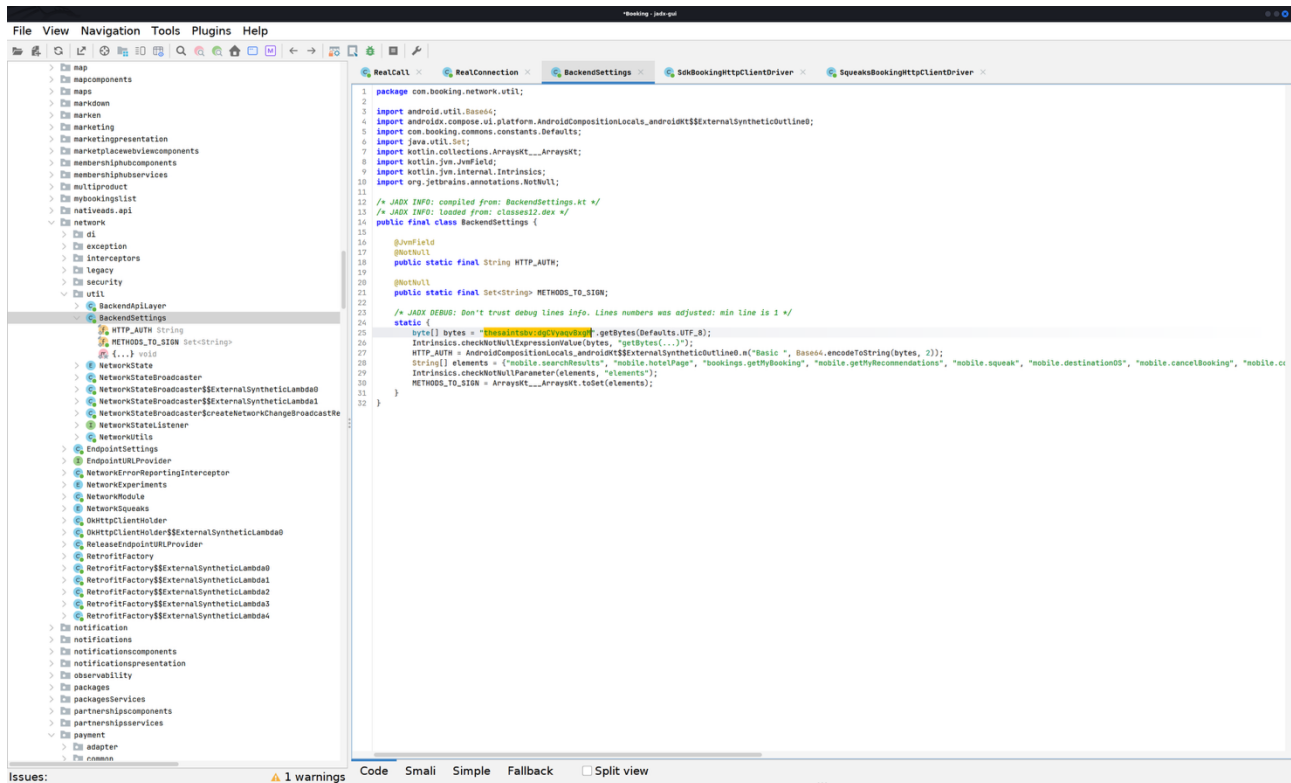


```
alfo3du@Kali: ~  
$ echo dGhlc2FpbmRzYnY6ZGdDVnlhcXZCeGdN | base64 --decode  
thesaintsbv:dgCVyaqvBxgM  
$
```

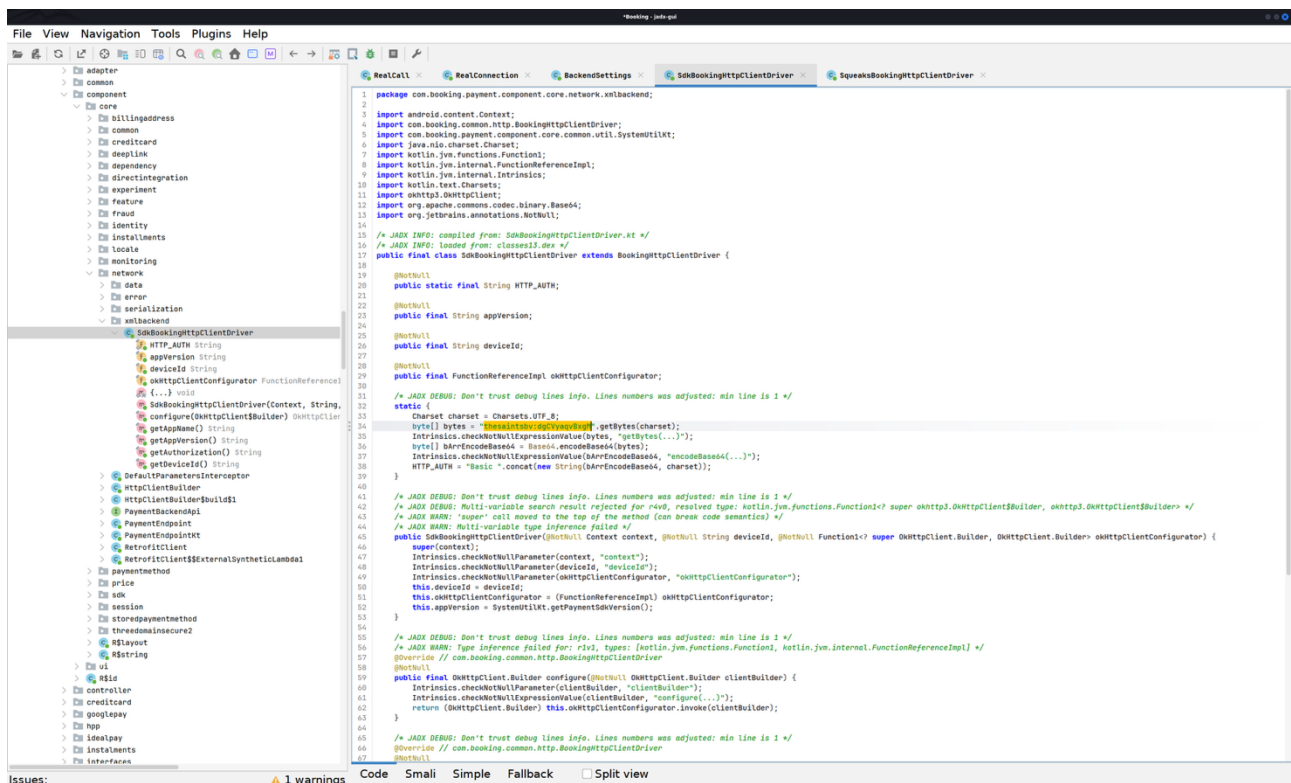
È stato effettuato *reverse engineering* tramite *Jadx GUI*; la ricerca della stringa decodificata rivela le classi di Booking.com che la contengono:



Le credenziali *hard coded* vengono utilizzate in più punti dell'app, potenzialmente in buona parte del traffico online API di Booking.com, data la loro presenza in classi denominate *BackendSettings* situata in package `com.booking.network.util` e *SdkBookingHttpClientDriver* situata in package `com.booking.payment.component.core.network.xmlbackend`:



```
1 package com.booking.network.util;
2
3 import android.util.Base64;
4 import androidx.compose.ui.platform.AndroidCompositionLocals_androidKt$ExternalSyntheticOutLine0;
5 import com.booking.common.constants.Defaults;
6 import java.util.Set;
7 import kotlin.collections.ArraysKt___ArraysKt;
8 import kotlin.jvm.functions.Function1;
9 import kotlin.jvm.internal.Intrinsics;
10 import org.jetbrains.annotations.NotNull;
11
12 /* JADX INFO: compiled from: BackendSettings.kt */
13 /* JADX INFO: loaded from: classes2.dex */
14 public final class BackendSettings {
15
16     @JvmField
17     @NotNull
18     public static final String HTTP_AUTH;
19
20     @NotNull
21     public static final Set<String> METHODS_TO_SIGN;
22
23     /* JADX DEBUG: Don't trust debug lines info. Lines numbers was adjusted: min line is 1 */
24     static {
25         byte[] bytes = BackendSettings.class.getResource("BackendSettings.kt").getBytes(Defaults.UTF_8);
26         Intrinsics.checkNotNullExpressionValue(bytes, "getBytes(...)");
27         HTTP_AUTH = AndroidCompositionLocals_androidKt$ExternalSyntheticOutLine0.m("Basic ", Base64.encodeToString(bytes, 2));
28         String[] elements = {"mobile.searchResults", "mobile.hotelPage", "bookings.getBooking", "mobile.getRecommendations", "mobile.sneak", "mobile.destinationDS", "mobile.cancelBooking", "mobile.c"};
29         Intrinsics.checkNotNullParameter(elements, "elements");
30         METHODS_TO_SIGN = ArraysKt___ArraysKt.toSet(elements);
31     }
32 }
```



```
1 package com.booking.payment.component.core.network.xmlbackend;
2
3 import android.content.Context;
4 import com.booking.common.http.BookingHttpClientDriver;
5 import com.booking.payment.component.common.util.SystemUtilKit;
6 import java.nio.charset.Charset;
7 import kotlin.jvm.functions.Function1;
8 import kotlin.jvm.internal.FunctionReferenceImpl;
9 import kotlin.jvm.internal.Intrinsics;
10 import kotlin.text.Charsets;
11 import okhttp3.OkHttpClient;
12 import org.apache.commons.codec.binary.Base64;
13 import org.jetbrains.annotations.NotNull;
14
15 /* JADX INFO: compiled from: SdkBookingHttpClientDriver.kt */
16 /* JADX INFO: loaded from: classes3.dex */
17 public final class SdkBookingHttpClientDriver extends BookingHttpClientDriver {
18
19     @NotNull
20     public static final String HTTP_AUTH;
21
22     @NotNull
23     public static final String appVersion;
24
25     @NotNull
26     public static final String deviceId;
27
28     @NotNull
29     public static final FunctionReferenceImpl<OkHttpClient> okHttpClientConfigurator;
30
31     /* JADX DEBUG: Don't trust debug lines info. Lines numbers was adjusted: min line is 1 */
32     static {
33         Charset charset = Charsets.UTF_8;
34         byte[] bytes = SdkBookingHttpClientDriver.class.getResource("SdkBookingHttpClientDriver.kt").getBytes(charset);
35         Intrinsics.checkNotNullExpressionValue(bytes, "getBytes(...)");
36         byte[] bArrEncodedBase64 = Base64.encodeBase64(bytes);
37         Intrinsics.checkNotNullExpressionValue(bArrEncodedBase64, "encodeBase64(...)");
38         HTTP_AUTH = "Basic ".concat(new String(bArrEncodedBase64, charset));
39     }
40
41     /* JADX DEBUG: Don't trust debug lines info. Lines numbers was adjusted: min line is 1 */
42     /* JADX WARN: Multi-variable search result rejected for <@>, resolved type: kotlin.jvm.functions.Function1< super okhttp3.OkHttpClient.Builder, okhttp3.OkHttpClient.Builder> */
43     /* JADX WARN: 'super' call moved to the top of the method (can break code semantics) */
44     /* JADX WARN: Kotlin variable type inference failed for */
45     public SdkBookingHttpClientDriver(@NotNull Context context, @NotNull String deviceId, @NotNull Function1< super OkHttpClient.Builder, OkHttpClient.Builder> okHttpClientConfigurator) {
46         super(context);
47         Intrinsics.checkNotNullParameter(context, "context");
48         Intrinsics.checkNotNullParameter(deviceId, "deviceId");
49         Intrinsics.checkNotNullParameter(okHttpClientConfigurator, "okHttpClientConfigurator");
50         this.deviceId = deviceId;
51         this.okHttpClientConfigurator = (FunctionReferenceImpl) okHttpClientConfigurator;
52         this.appVersion = SystemUtilKit.getPaymentSdkVersion();
53     }
54
55     /* JADX DEBUG: Don't trust debug lines info. Lines numbers was adjusted: min line is 1 */
56     /* JADX WARN: Type inference failed for: r1v1, types: (kotlin.jvm.functions.Function1, kotlin.jvm.internal.FunctionReferenceImpl) */
57     @Override // com.booking.common.http.BookingHttpClientDriver
58     @NotNull
59     public final OkHttpClient.Builder configure(@NotNull OkHttpClient.Builder clientBuilder) {
60         Intrinsics.checkNotNullParameter(clientBuilder, "clientBuilder");
61         Intrinsics.checkNotNullExpressionValue(clientBuilder, "configure(...)");
62         return (OkHttpClient.Builder) this.okHttpClientConfigurator.invoke(clientBuilder);
63     }
64
65     /* JADX DEBUG: Don't trust debug lines info. Lines numbers was adjusted: min line is 1 */
66     @Override // com.booking.common.http.BookingHttpClientDriver
67     @NotNull
68     public final OkHttpClient.Builder configure(@NotNull OkHttpClient.Builder clientBuilder) {
69         Intrinsics.checkNotNullParameter(clientBuilder, "clientBuilder");
70         Intrinsics.checkNotNullExpressionValue(clientBuilder, "configure(...)");
71         return (OkHttpClient.Builder) this.okHttpClientConfigurator.invoke(clientBuilder);
72     }
73 }
```

Nel codice si vede chiaramente la logica di codifica in Base64 e la creazione della stringa di autenticazione che inizia con *Basic*.

È possibile copiare le richieste catturate dal proxy come comandi *cURL*. L'esecuzione di tale comando in un terminale esterno permette di recuperare ugualmente la risposta dell'API senza che quest'ultima verifichi il client, evidenziandone una potenziale vulnerabilità:

[illegible]

Da notare l'utilizzo dell'autorizzazione codificata in Base64 nella richiesta *cURL*. Se si ripete il comando omettendo esclusivamente tale header, l'API rifiuterà la nostra richiesta. Questo dimostra chiaramente che le credenziali *hard coded* nel codice (facilmente accessibili) sono effettivamente necessarie e utilizzate dall'API e non una stringa di debug inutilizzata e rimasta nel codice per errore.

```
alfo3du@Kali: ~  
alfo3du@Kali: ~  
alfo3du@Kali: ~  
alfo3du@Kali: ~  
alfo3du@Kali: ~  
alfo3du@Kali: ~/Mobile S...  
alfo3du@Kali: ~  
alfo3du@Kali: ~  
  
[alfo3du@Kali]~$ curl -H "Host: mobile-apps.booking.com" -H "x-access-token: CAESoyS5BAUfAIChQSPtAFBd8XVBgWgrGVUoAhlMlPqVzJhp5nKZvo8FvHzTfyFGOMG8KraevEhcIcVcSALgc3vkNkSiKu-V7bulw7dE5W  
a-v5sg8re0dC_59YCIfrki1JA_CGS0uESDw2BppkLYIKxWcup1TuFS9G2JDwhMGFM3rfgc0bnHns7pPKNPJUmrgRGTATfhLz1e8xyfZEuAwNmZqj3YcvndFsurydbnbZf3Mjqac-qR2UB9W719xFgbAf8HydenFoebk8ZxKpQyQFKAK8scndGDGAVJmLVWdvosahkdXzo  
Blw9yL5ObmgSntLL0ryZMu0Ph9DbGaPm2IFC_abKFvSaVEEsue3VihUHF_xktHSxoPyPalTsW9FXlFDOniFAWhZjWVR7jCLLEIOI0O8U3kZX2TPbVCRGUDEmu7gmwfY03bvAS8MveVe-IDxTPXXoRa8WB4uaC7_dEtNXEDBAQTdgwZptA_VowdfG0SB8BnjXTX2hd-Xen-hheSt7KFIPI  
JxGdZYayzu3dx3l3_wvr31Y5B_b05kg8x8-IezPdPhsd25v301_6vtL7rk07uHx_MbdnHBKMjG5X4EF3zTFw41DaBd067XlW7Uqc9TbcgkrfNWfGLxc0iRFPPG4x78nTSrq0PU8o-1-qwRSklQY10ehqw-6MZYPaiZe-5vxonJy1ORJxAIhyKy9iIdGAKoSmlKu_gtaQxbkAAAvSQJ  
JxGdwq1z5od7-x7CUxTgnMoKAdMPToKfnQv6w82LcBLXIQt16jHEVLvy3WFnnUFDJq59DZR5IRHI FXZYCNBchajkJClly53J6b7YskGGKWRY4qqwxkziBxCsPS15n948CH2LTtc3908_djsID8XdshYfIKJkItGuDDAX78YsDK1v57ZmNaQDBF93wzJKJXFfwqaY3WNaUHAt8hv6VVf  
ZimULfF6omLT7H52Nu9p33rICfa-z551-ONLmwzU5Wjmpps-gIGAiOB8TD6hdydBj8" -H "x-booking-lam-access-token: CAESoyS5BAUfAIChQSPtAFBd8XVBgWgrGVUoAhlMlPqVzJhp5nKZvo8FvHzTfyFGOMG8K  
raevEhcIcVcSALgc3vkNkSiKu-V7bulw7dE5W-a-v5sg8re0dC_59YCIfrki1JA_CGS0uESDw2BppkLYIKxWcup1TuFS9G2JDwhMGFM3rfgc0bnHns7pPKNPJUmrgRGTATfhLz1e8xyfZEuAwNmZqj3YcvndFsurydbnbZf3Mjqac-qR2UB9W719xFgbAf8HydenFoebk8ZxKpQyQFKAK8scndGDGAVJmLVWdvosahkdXzoBlnw9yL5ObmgSntLL0ryZMu0Ph9DbGaPm2IFC_abKFvSaVEEsue3VihUHF_xktHSxoPyPalTsW9FXlFDOniFAWhZjWVR7jCLLEIOI0O8U3kZX2TPbVCRGUDEmu7gmwfY03bvAS8MveVe-IDxTPXXoRa8WB4uaC7_dEtNXEDBAQTdgwZptA_VowdfG0SB8BnjXTX2hd-Xen-hheSt7KFIPIJxGdZYayzu3dx3l3_wvr31Y5B_b05kg8x8-IezPdPhsd25v301_6vtL7rk07uHx_MbdnHBKMjG5X4EF3zTFw41DaBd067XlW7Uqc9TbcgkrfNWfGLxc0iRFPPG4x78nTSrq0PU8o-1-qwRSklQY10ehqw-6MZYPaiZe-5vxonJy1ORJxAIhyKy9iIdGAKoSmlKu_gtaQxbkAAAvSQJxGdwq1z5od7-x7CUxTgnMoKAdMPToKfnQv6w82LcBLXIQt16jHEVLvy3WFnnUFDJq59DZR5IRHI FXZYCNBchajkJClly53J6b7YskGGKWRY4qqwxkziBxCsPS15n948CH2LTtc3908_djsID8XdshYfIKJkItGuDDAX78YsDK1v57ZmNaQDBF93wzJKJXFfwqaY3WNaUHAt8hv6VVfZimULfF6omLT7H52Nu9p33rICfa-z551-ONLmwzU5Wjmpps-gIGAiOB8TD6hdydBj8" -H "X-library: okhttp-network-api" -H "user-agent: Booking.App/60.2.1.11 Android/13; Type: mobile; App  
Store: huawei_paid_store; Brand: google; Model: sdk_gphone64_arm64;" -H "x-content-type: application/json; charset=utf-8" -H "x-response-checksum: 0" --data-binary '{"device_i  
d":{"vae21a5a-e84d-4bfa-ab4d-a16d-50374d9388c5network_type:wifiLanguagecode:en-usdisplay:normal_xxhdpiAffiliate_id:337862"  
-androidId:device_id:aes21a5a-e84d-4bfa-ab4d-a16d-50374d9388c5network_type:wifiLanguagecode:en-usdisplay:normal_xxhdpiAffiliate_id:337862"  
Authorization required (HTTP Basic)
```


Con lo stesso terminale, è possibile riprodurre richieste cURL provenienti da un'altra istanza dell'applicazione. Per esempio, questa richiesta all' API di Booking è stata catturata tramite proxy installato su un altro telefono Android; infatti, i vari ID e token sono diversi da prima e corrispondono al nuovo dispositivo in questione:

[illegible]

Si può osservare che alcuni valori differiscono tra le due richieste, come quello evidenziato in giallo, in quanto legati al contesto del dispositivo utilizzato nella cattura. La risposta dell'API varia coerentemente in base ai parametri forniti nella richiesta. Le richieste possono dunque essere riprodotte esternamente tramite *cURL*, ottenendo risposte coerenti con i parametri utilizzati.

[illegible]

[illegible]

Ulteriori test sono necessari per determinare se la manipolazione dei parametri all'interno delle richieste HTTP intercettate tramite Charles Proxy possa avere impatti più ampi sul comportamento delle API, attraverso l'analisi di ulteriori endpoint e variazioni dei valori inviati.